

Защита контроллера домена предприятия

Лабораторная работа №1 · Киберполигон Ampire

Назармамадов Умед Джамshedович

2026-10-06

Содержание I

- 1 Информация
- 2 Вводная часть
- 3 Расследование и устранение
- 4 Результаты

Раздел 1

Информация

- Назармамадов Умед Джамshedович
- студент, группа НФИбд-02-23
- Российский университет дружбы народов
- курс «Защита сетей и кибербезопасность»
- umednazarmamadov40@gmail.com

Раздел 2

Вводная часть

- **Цель:** расследовать инцидент на киберполигоне Ampire (сценарий №2 «Защита контроллера домена предприятия») и устранить все уязвимости.
- **Задачи:**
 - обнаружить этапы атаки по данным ViPNet IDS NS;
 - задокументировать каждый этап карточкой инцидента;
 - устранить причину уязвимости на поражённом узле;
 - подтвердить устранение по статусу полигона.

Сценарий атаки

Этап	Действие	Источник → Цель
1	SQL-инъекция → meterpreter	Kali → Web Server PHP (10.10.1.20)
2	Фишинг → meterpreter	Kali → Admin Workstation (10.10.4.10)
3	Перебор пароля RDP → захват AD	Web Server PHP → MS AD (10.10.2.10)

Внешний атакующий закрепляется на периметре и движется вглубь сети к контроллеру домена.

Раздел 3

Расследование и устранение

Уязвимость 1. SQL-инъекция

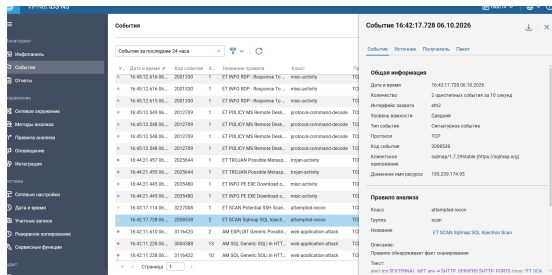


Рисунок 1: Событие ViPNet IDS NS: sqlmap-сканирование

- Карточка: источник Kali (195.239.174.11), актив Web Server PHP
- Устранение: ss -K убита сессия, в NewsController.php добавлена валидация `is_numeric($id)`
- Попутно обнаружен и остановлен туннель chisel на сервере

Карточка инцидента №1

Основная информация

Чат

Новый

Основная информация

Дата и время события

06.10.2026 16:42

Описание

Зафиксировано сканирование веб-сервера PHP (195.239.174.95/10.10.1.20) с помощью sqlmap 1.7.2 с IP 195.239.174.11. Выявлен уязвимый параметр, впоследствии использованный для загрузки вредоносного файла.

Индикаторы компрометации

attempted-recon/sqlmap

Рекомендации

Добавить валидацию входных параметров (is_numeric для id), заблокировать 195.239.174.11, завершить активные сессии с данным адресом.

Оценка

☆☆☆☆

Автор

Н Назармамадов Умед @1032225205

Ответственный

Ничего не выбрано

Источник

195.239.174.11 (Kali) x

Поражённые активы

10.10.1.20 (Web Server PHP) x

Рисунок 2: Заполненная карточка: SQL-инъекция

Уязвимость 2. Компрометация рабочей станции администратора

События

События за последние 24 часа

У.	Дата и время	И	Код события	К.	Название правила	Класс	Пг
	16:45:12.616.06...		2001330	1	ET INFO RDP - Response To ...	info-activity	TCT
	16:45:12.616.06...		2001330	1	ET INFO RDP - Response To ...	info-activity	TCT
	16:45:12.615.06...		2001330	1	ET INFO RDP - Response To ...	info-activity	TCT
	16:45:12.549.06...		2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCT
	16:45:12.548.06...		2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCT
	16:45:12.548.06...		2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCT
	16:45:12.548.06...		2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCT
	16:44:21.457.06...		2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCT
	16:44:21.455.06...		2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCT
	16:44:21.445.06...		2035480	1	ET INFO PE EXE Download o...	info-activity	TCT
	16:44:21.445.06...		2035480	1	ET INFO PE EXE Download o...	info-activity	TCT
	16:43:17.114.06...		3227006	1	ET SCAN Potential SSH Scan...	attempted-recon	TCT
	16:42:17.729.06...		2030558	2	ET SCAN Signmap SQL Inject...	attempted-recon	TCT
	16:42:11.610.06...		3116420	2	AM EXPLOIT Generic Possibl...	web-application-attack	TCT
	16:42:11.228.06...		3904388	13	AM SQL Generic SQLi in HTT...	web-application-attack	TCT
	16:42:11.228.06...		3116422	10	AM SQL Generic SQLi in HTT...	web-application-attack	TCT

Событие 16:44:21.457.06.10.2026

Событие

Источник

Получатель

Панель

Общая информация

Дата и время

Интерфейс завета

Уровень важности

Тип события

Протокол

Код события

Правило анализа

Класс

Группа

Название

Описание:

Текст:

event type EXTERNAL_NET any -> \$HOME_NET any (msg: "ET TROJAN Possible M

atched Payload Common Construct Bind_API (from server)", Src: from_servers

atched_content: "160.89.45.317", content: "64.66", distance: 1, within: 2, content: "3

.8.80", distance: 1, within: 2, content: "160.89.52.14.89.72.28.81.57.4a.26.31.10", data event: "2", content: "1a.3e.63.7a.82.2a.28.e1.e1.65.01.61.62", within: 1, content: "150.37.46.52.10", distance: 1, within: 1, content: "trojan-activity.sig", 2025644}

Рисунок 3: Событие ViPNet IDS NS: Metasploit payload

- Фишинговое письмо → meterpreter-сессия на Admin Workstation
- Устранение: taskkill сессии, включён Windows Defender (DisableAntiSpyware, DisableRealtimeMonitoring убраны из реестра), перезапущена служба WinDefend
- Подтверждено: RealTimeProtectionEnabled = True, AntivirusEnabled = True

Карточка инцидента №2

Основная информация

Чат

Новый

Основная информация

Дата и время события

06.10.2026 16:44

Описание

Закреплено сетевая активность, характерная для Metasploit Payload (Bind-API from server) между атакующим 195.239.174.11 и рабочей станцией администратора 10.10.4.10. Свидетельствует об успешной компрометации узла через фишинговое письмо с вредоносным вложением

Индикаторы компрометации

trojan-activity/Metasploit Payload

Рекомендации

Завершить сессию с атакующим (netstat-ano+taskkill), включить Real-time Protection Windows Defender, провести полное сканирование узла

Оценка

☆☆☆☆

Автор

Н Назармамадов Умед @1032225205

Ответственный

Ничего не выбрано

Источник

195.239.174.11 (Kali) x

Поражённые активы

10.10.4.10 (Administrator Workstation) x

Рисунок 4: Заполненная карточка: компрометация рабочей станции

Карточка инцидента №3

Основная информация

Чат

Новый ▾

Основная информация

Дата и время события ⓘ

06.10.2026 16:45

Описание ⓘ

С уже скомпрометированного узла 10.10.1.20 зафиксирован массовый перебор пароля администратора домена по RDP (порт 3389) на контроллер домена 10.10.2.10. Множественные запросы аутентификации за короткий промежуток времени (29 за 10 сек) свидетельствует об атаке типа brute-force. Непосредственно после зафиксировано активность Metasploit на этом же направлении, что указывает на успешный захват учётной записи и закрепление на AD

Индикаторы компрометации ⓘ

protocol-command-decode/MS Remote Desktop Administrator Login Request/brute-force

Рекомендации ⓘ

Сменить пароль администратора AD на сложный, проверить и удалить все добавленные нарушителем учётные записи в Active Directory Users and Computers, ограничить доступ по RDP к контроллеру домена только с доверенных узлов

Оценка

☆☆☆☆☆

Автор

Н Назармамадов Умед @1032225205

Ответственный

Ничего не выбрано ▾

Источник ⓘ

10.10.1.20 (Web Server PHP) x ▾

Поражённые активы ⓘ

10.10.2.10 (MS Active Directory) x ▾

Раздел 4

Результаты

Итоговые статусы

Уязвимость	Узел	Статус
SQL Injection	Web Server PHP	Устранено
Web portal meterpreter	Web Server PHP	Устранено
Windows Defender	Admin Workstation	Устранено (подтверждено командами)
Admin meterpreter	Admin Workstation	Устранено
AD Admin Password	MS Active Directory	Устранено
AD user	MS Active Directory	Устранено

Устранение одной уязвимости не останавливает атакующего, уже закрепившегося на другом узле: только последовательное закрытие всей цепочки — от периметра до контроллера домена — реально останавливает атаку.